

Avance semana 5

Avance semanal

Divier Jácamo Álvarez

Cetav

Rol: Analista Soc L1

Fecha 10/02/26

Procedimiento de análisis inicial de alertas

El procedimiento de análisis inicial de alertas tiene como objetivo establecer una metodología estructurada para la evaluación temprana de las notificaciones generadas por los sistemas de monitoreo o reporte institucional este proceso busca identificar la validez, relevancia y nivel de prioridad de cada alerta, con el fin de facilitar una toma de decisiones informada y oportuna.

El análisis inicia con la recepción y registro de la alerta, seguida de la verificación de la información asociada para descartar errores o falsos positivos posteriormente, la alerta es clasificada de acuerdo con criterios previamente definidos, tales como severidad, urgencia e impacto potencial a continuación, se realiza un análisis contextual que considera antecedentes, condiciones actuales del sistema y posibles causas del evento finalmente, con base en los resultados obtenidos, se determinan las acciones iniciales correspondientes, las cuales pueden incluir el seguimiento, el escalamiento o el cierre de la alerta, asegurando en todo momento la adecuada documentación del proceso este procedimiento contribuye a una gestión más eficiente y sistemática de incidentes dentro de la organización.

Validación de alertas de seguridad

Introducción

El monitoreo continuo de los eventos de seguridad es una función esencial del SOC. por sistemas como SIEM, EDR o IDS/IPS reflejan hechos reales. Validar correctamente estas alertas es una responsabilidad clave del SOC Nivel 1 que actúa como la primera línea de defensa contra posibles ciberamenazas en los hospitales psiquiátricos, donde se manejan datos clínicos altamente sensibles y sistemas críticos para la atención médica, una validación incorrecta puede tener consecuencias importantes. Por lo tanto, es importante contar con un procedimiento claro y documentado que permita a un analista de Nivel 1 evaluar sistemáticamente la legitimidad de una alerta antes de que se cierre o se escale.

Alcance

El procedimiento descrito sólo aplica para la etapa de validación inicial de las alertas de seguridad realizadas por el SOC L1 esto finaliza con la decisión de cerrar la alarma o elevarla al nivel SOC 2 no incluye operaciones de contención, erradicación o recuperación.

Recepción de alarma y revisión inicial.

El analista de SOC L1 debe leer la alerta en su totalidad, especificando el tipo de evento, la hora del evento, la herramienta que lo generó y la regla o firma asociada.

Reconocimiento de la fuente del descubrimiento.

Se ha confirmado que la alerta proviene de una fuente confiable y configurada correctamente, lo que garantiza que no se trata de un error en la herramienta ni de una mala parametrización.

Identificación de bienes afectados

El analista identifica al agente involucrado determina su nivel crítico en el hospital.

Análisis del contexto de activos y usuarios.

El comportamiento normal de un activo o usuario se evalúa en términos de horarios de trabajo, funciones clínicas o administrativas y acceso preautorizado.

Revisar publicaciones relacionadas

El analista examina los registros relevantes en busca de actividad anómala, patrones sospechosos o eventos recurrentes que respalden una alerta. Conexión con otros eventos

Durante el mismo período de tiempo, se verifican alertas similares o relacionadas que pueden indicar un ataque en curso o una acción coordinada.

Respaldo Contra Acciones Legales

Comprueba si el evento se puede atribuir a mantenimiento programado, actualizaciones de software, pruebas internas o actividades preaprobadas

Identificar métricas de participación

El analista busca indicadores de compromiso, como direcciones IP maliciosas, dominios sospechosos, hashes conocidos o comportamiento de ataque típico.

Evaluación de posibles consecuencias.

Se analiza el impacto potencial del evento en la confidencialidad, integridad y disponibilidad de la información, priorizando los datos clínicos y los servicios médicos.

Clasificación inicial de eventos.

Según la evidencia recopilada, el evento se clasifica como un falso positivo, un evento benigno o un posible evento de seguridad

Documentación de análisis

Todas las acciones, evidencias y hallazgos deben registrarse en el sistema de gestión de incidentes para su auditabilidad y trazabilidad. Decisión de cerrar o escalar

Finalmente, el analista decide cerrar la alerta si no hay riesgo o escalarla al SOC L2 si se encuentran signos claros de un incidente real.

Tabla de alertas de seguridad y acciones iniciales del analista

Tipo de alerta	Descripción General	Acción Inicial
Acceso no autorizado	Intentos de acceso fallidos desde ubicaciones desconocidas	Verificar identidad del usuario revisar logs de autenticación y validar el acceso
Malware detectado	Identificación de software malicioso en un equipo o servidor	Confirmar detención revisar tipo de malware y evaluar si el archivo fue ejecutado
Actividad anómala del usuario	Comportamientos fuera del patrón normal del usuario	Analizar historial de actividad validar si corresponde a funciones laborales
Trafico de red sospechoso	Comunicación con direcciones ip	Revisar logs de red y confirmar reputación de ip
Exfiltración de datos	Trasferencias inusuales de información	Identificar volumen y tipo de datos involucrados y verificar legitimidad
Escalamiento de privilegios	Incremento no autorizado de permisos	Validar cambios recientes de roles y revisar registros de sistema
Alertas de ransomware	Comportamientos asociados cifrado masivo de archivos	Verificar procesos activos y evaluar impacto potencial
Fallos repetitivos de autenticación	Múltiples intentos fallidos de inicio de sesión	Determinar si se trata de error de usuario o posible ataque de fuerza bruta
Cambios no automatizados en sistemas	Modificaciones en configuraciones criticas	Revisar historial de cambios y confirmar si fueron aprobados

Alertas de dispositivos médicos	Actividad anómala en equipos conectados	Verificar funcionamiento normal y notificar si afecta servicios clínicos
---------------------------------	---	--

Referencias

García, J., & Fernández, P. (2020). *Ciberseguridad en entornos hospitalarios: protección de datos y continuidad del servicio*. Editorial Médica Panamericana.

Hutchins, E. M., Cloppert, M. J., & Amin, R. M. (2011). Intelligence-driven computer network defense informed by analysis of adversary campaigns and intrusion kill chains. *Leading Issues in Information Warfare & Security Research*, 1(1), 80–106.

Peltier, T. R. (2016). *Information security policies, procedures, and standards: guidelines for effective information security management*. Auerbach Publications.

Whitman, M. E., & Mattord, H. J. (2022). *Principles of information security* (7th ed.). Cengage Learning.